

Delivering excellence to
education is our thing



Document prepared for Brighton Hill Community School

Brighton Way,
Basingstoke,
RG22 4HS

01256 350606

Contents

Confidentiality	3
Contacts	3
Company Summary	4
Document Summary	5
Executive Summary	7
Terminology Used Within This Document	7
Scope	7
Exploitable Vulnerabilities	8-12
Remediations	13

Confidentiality

All rights reserved. The information contained in this document is confidential. No part of this document may be reproduced or transmitted without permission from the document owner. Use of any copyright notice does not imply unrestricted public access to any part of this document. All trademarks are acknowledged as the property of their rightful owners.

Contacts

For further information please contact.

Luke Nicolaou

Co-Founder & Chief Executive Officer

lnicolaou@eduthing.co.uk

Zahid Chady

Chief Operations Officer

zchady@eduthing.co.uk

Luke Holland

Chief Technology Officer

lholland@eduthing.co.uk

Company Summary

We are a forward thinking, proactive and flexible company that provides managed IT services for schools, academies and multi academy trusts in the primary, secondary, special and independent sector.

Working solely within the education sector, we have gained a unique insight into schools and are now the largest IT Managed Service provider in Surrey, with a growing number of schools within the London Boroughs and surrounding areas.

Although we are a young and relatively new company we have in excess of 50 employees with a significant number of years' experience within education, our support services have been designed specifically for schools. We understand that schools come in all shapes and sizes and that our support needs to be completely flexible to accommodate the diverse range within the UK.

Our success is due to our strategic approach to both develop and strengthen your IT solution, whilst bridging the gap between your school's learning vision and current infrastructure. However, what really sets us apart is our forward-thinking and proactive approach to outsourcing. We understand that in today's budget sensitive economy, it's becoming increasingly important for school leaders to find a way to achieve a high level of IT delivery and support whilst also keeping costs to a minimum.

That is why we offer a complete 'wrap around' service to all our schools, offering a number of services ranging from service desk support, dedicated onsite engineers, OnDemand service for those high impact issues outside of your scheduled onsite visits, network & infrastructure replacements, and a number of cloud-based technologies. We provide you with a comprehensive service, allowing you to get the most out of the current systems you have in place, whilst reducing IT issues and maximising teaching and learning time.

We pride ourselves on providing the highest level of client service and are really pleased to have an exceptionally high level of customer satisfaction, with over 88% of calls being rated as excellent. To further our commitment to customer service, we only provide our IT Managed Services to schools within two hours of our offices located in Walton-on-Thames.

We have accreditations with Sophos, Schools Broadband, and are very proud to be a Google for Education accredited partner, and one of only a small number of companies to qualify. We have also been selected as part of the recent DfE Platform Provisioning Programme, enabling schools to adopt fully funded cloud technologies during the coronavirus pandemic.

Working alongside many IT hardware and software suppliers, including ASUS, where we are a Platinum Partner and the largest stockist of ASUS Chromebooks in the UK supplying devices on a national level. Our partnerships allow us to provide a suite of software, hardware and services that complement one another, enabling you to gain the maximum value from your IT budget over a period of time.

The result of these partnerships and others is that we provide a comprehensive service allowing you to make the most of your system, whilst reducing IT issues and maximising classroom contact time.

In our view, the more that we can do to help support learning and teaching at your school, regardless of remote learning, blended learning, hybrid learning, physical or virtual learning with any of our IT services, is time well spent.

Luke Nicolaou

Co-Founder & Chief Executive Officer

Document Summary

Version History

Version	Version Date	Comment	Modified by
1	August 2023		William Finch

Purpose of the Document

This document is designed to give an overview of the security of the school IT network. The document may highlight areas of concern which may result in further auditing / investigation. Remediations will be discussed with your school and testing will be carried out before making any major changes.

School Information

Headteacher	Mr Christopher Edwards
Academy Trust	South Farnham Educational Trust
DfE number:	850/4182

IT Vulnerability Assessment Document

Executive Summary

This executive summary presents the findings of a recent vulnerability assessment conducted on the IT infrastructure of Brighton Hill Community School. The purpose of this assessment was to identify potential weaknesses in the system that could be exploited by malicious actors due to the unknown entry point of the recent cyber incident the school had experienced. The assessment revealed critical, high, medium, and low severity vulnerabilities across various devices and applications.

By proactively addressing these vulnerabilities, implementing robust security measures, and establishing a regular patch management regime, Brighton Hill Community School can significantly mitigate the risk of potential cyber-attacks and safeguard the integrity of its IT infrastructure. Given the constantly evolving threat landscape, continuous monitoring and proactive security measures are vital for maintaining a secure environment.

The following vulnerabilities were identified:

Severity	Count
Critical	4
High	6
Medium	4
Low	2

The vulnerability assessment has revealed the following items that require immediate attention:

Terminology Used Within This Document

Exploit

A software tool designed to take advantage of a flaw in a computer system, typically for malicious purposes such as installing malware

Vulnerabilities

A vulnerability is a security weakness in a computer system that permits unauthorised or unwelcome access.

Scope

Surface area on which the vulnerability assessment will take place. Typically conducted on IT infrastructure and client workstations.

Scope

This report includes a penetration test report based on the entire range of **Brighton Hill Community School**. Targeting devices within the main network VLANs:

- 10.194.120.1-10.194.124.254

Exploitable Vulnerabilities

Severity	Vulnerability	IP/DNS/Devices	Number of instances
Critical	Microsoft RDP RCE (CVE-2019-0708)	BHCCWEB.BHS.local BHCS-Cashless.BHS.local	2
Critical	Apache < 2.4.49 Multiple Vulnerabilities	BHCCWEB.BHS.local	2
Critical	ArubaOS-Switch Ripple20 Multiple Vulnerabilities (ARUBA-PSA-2020-006)	10.194.120.200	1
Critical	Microsoft Message Queuing RCE (CVE-2023-21554, QueueJumper)	BHCS-WebPublish.BHS.local	1
High	OpenSSL < 0.9.8w ASN.1 asn1_d2i_read_bio Memory Corruption	BHCCWEB.BHS.local	2
High	PHP < 5.3.12 / 5.4.2 CGI Query String Code Execution	BHCCWEB.BHS.local	2
High	PHP 5.3.x < 5.3.14 Multiple Vulnerabilities	BHCCWEB.BHS.local	2
High	PHP 5.3.x < 5.3.28 Multiple OpenSSL Vulnerabilities	BHCCWEB.BHS.local	2
High	Apache 2.2.x < 2.2.28 Multiple Vulnerabilities	BHCCWEB.BHS.local	2
High	SSL Certificate Signed Using Weak Hashing Algorithm	10.194.120.1 10.194.120.171 BHCCWEB.BHS.local BHCS-Cashless.BHS.local BHCS-WebPublish.BHS.local	6
Medium	SMB Signing not required	Windows Machines	287
Medium	OpenSSL 0.9.8 < 0.9.8za Multiple Vulnerabilities	BHCCWEB.BHS.local	2
Medium	Acme mini_httpd Protocol String Handling Memory Disclosure	10.194.120.171	2
Medium	Dropbear SSH Authorization-pending Connection Saturation DoS	10.194.120.171	1
Low	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)	10.194.120.42 10.194.120.171 10.194.121.49 BHCCWEB.BHS.local BHCS-WebPublish.BHS.local	7
Low	OpenSSL 0.9.8 < 0.9.8zc Multiple Vulnerabilities (POODLE)	BHCCWEB.BHS.local	2

Microsoft RDP RCE (CVE-2019-0708):

A remote code execution vulnerability exists in Remote Desktop Services – formerly known as Terminal Services – when an unauthenticated attacker connects to the target system using RDP and sends specially crafted requests. This vulnerability is pre-authentication and requires no user interaction. An attacker who successfully exploited this vulnerability could execute arbitrary code on the target system. An attacker could then install programs; view, change, or delete data; or create new accounts with full user rights.

Apache < 2.4.49 Multiple Vulnerabilities:

The version of Apache httpd installed on the remote host is prior to 2.4.49. It is, therefore, affected by a vulnerability as referenced in the 2.4.49 changelog.

- A crafted request uri-path can cause mod_proxy to forward the request to an origin server chosen by the remote user. (CVE-2021-40438)

ArubaOS-Switch Ripple20 Multiple Vulnerabilities (ARUBA-PSA-2020-006):

The version of ArubaOS-Switch installed on the remote host is affected by multiple vulnerabilities in the Treck IP stack implementation. The vulnerabilities are collectively known as Ripple20, and can result in remote code execution, denial of service (DoS), and information disclosure by remote, unauthenticated attackers.

Microsoft Message Queuing RCE (CVE-2023-21554, QueueJumper):

The Microsoft Message Queuing running on the remote host is affected by a remote code execution vulnerability. An unauthenticated remote attacker can exploit this, via a specially crafted message, to execute arbitrary code on the remote host.

OpenSSL < 0.9.8w ASN.1 asn1_d2i_read_bio Memory Corruption:

According to its banner, the remote web server is running a version of OpenSSL earlier than 0.9.8w. As such, the OpenSSL library itself is reportedly affected by a memory corruption vulnerability via an integer truncation error in the function 'asn1_d2i_read_bio' when reading ASN.1 DER format data.

Applications using the 'BIO' or 'FILE' based functions (i.e., 'd2i_*_bio' or 'd2i_*_fp' functions) are affected by this issue.

Also affected are 'S/MIME' or 'CMS' applications using 'SMIME_read_PKCS7' or 'SMIME_read_CMS' parsers. The OpenSSL command line utility is affected if used to handle untrusted DER formatted data.

PHP < 5.3.12 / 5.4.2 CGI Query String Code Execution:

According to its banner, the version of PHP installed on the remote host is earlier than 5.3.12 / 5.4.2, and as such is potentially affected by a remote code execution and information disclosure vulnerability.

An error in the file 'sapi/cgi/cgi_main.c' can allow a remote attacker to obtain PHP source code from the web server or to potentially execute arbitrary code. In vulnerable configurations, PHP treats certain query string parameters as command line arguments including switches such as '-s', '-d', and '-c'.

PHP 5.3.x < 5.3.14 Multiple Vulnerabilities:

According to its banner, the version of PHP installed on the remote host is 5.3.x earlier than 5.3.14, and is, therefore, potentially affected the following vulnerabilities :

- An integer overflow error exists in the function 'phar_parse_tarfile' in the file 'ext/phar/tar.c'. This error can lead to a heap-based buffer overflow when handling a maliciously crafted TAR file. Arbitrary code execution is possible due to this error. (CVE-2012-2386)
- A weakness exists in the 'crypt' function related to the DES implementation that can allow brute-force attacks. (CVE-2012-2143)
- Several design errors involving the incorrect parsing of PHP PDO prepared statements could lead to disclosure of sensitive information or denial of service. (CVE-2012-3450)
- A variable initialization error exists in the file 'ext/openssl/openssl.c' that can allow process memory contents to be disclosed when input data is of length zero. (CVE-2012-6113)

PHP 5.3.x < 5.3.28 Multiple OpenSSL Vulnerabilities:

According to its banner, the version of PHP installed on the remote host is 5.3.x prior to 5.3.28. It is, therefore, potentially affected by the following vulnerabilities :

- A flaw exists in the PHP OpenSSL extension's hostname identity check when handling certificates that contain hostnames with NULL bytes. An attacker could potentially exploit this flaw to conduct man-in-the-middle attacks to spoof SSL servers. Note that to exploit this issue, an attacker would need to obtain a carefully-crafted certificate signed by an authority that the client trusts. (CVE-2013-4073, CVE-2013-4248)
- A memory corruption flaw exists in the way the openssl_x509_parse() function of the PHP OpenSSL extension parsed X.509 certificates. A remote attacker could use this flaw to provide a malicious, self-signed certificate or a certificate signed by a trusted authority to a PHP application using the aforementioned function. This could cause the application to crash or possibly allow the attacker to execute arbitrary code with the privileges of the user running the PHP interpreter. (CVE-2013-6420)

Apache 2.2.x < 2.2.28 Multiple Vulnerabilities:

According to its banner, the version of Apache 2.2.x running on the remote host is prior to 2.2.28. It is, therefore, affected by the following vulnerabilities :

- A flaw exists within the 'mod_headers' module which allows a remote attacker to inject arbitrary headers. This is done by placing a header in the trailer portion of data being sent using chunked transfer encoding. (CVE-2013-5704)
- A flaw exists within the 'mod_deflate' module when handling highly compressed bodies. Using a specially crafted request, a remote attacker can exploit this to cause a denial of service by exhausting memory and CPU resources. (CVE-2014-0118)
- The 'mod_status' module contains a race condition that can be triggered when handling the scoreboard. A remote attacker can exploit this to cause a denial of service, execute arbitrary code, or obtain sensitive credential information. (CVE-2014-0226)
- The 'mod_cgid' module lacks a time out mechanism. Using a specially crafted request, a remote attacker can use this flaw to cause a denial of service by causing child processes to linger indefinitely, eventually filling up the scoreboard. (CVE-2014-0231)

SSL Certificate Signed Using Weak Hashing Algorithm:

The remote service uses an SSL certificate chain that has been signed using a cryptographically weak hashing algorithm (e.g. MD2, MD4, MD5, or SHA1). These signature algorithms are known to be vulnerable to collision attacks. An attacker can exploit this to generate another certificate with the same digital signature, allowing an attacker to masquerade as the affected service.

SMB Signing not required:

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.

OpenSSL 0.9.8 < 0.9.8za Multiple Vulnerabilities:

According to its banner, the remote web server uses a version of OpenSSL 0.9.8 prior to 0.9.8za. The OpenSSL library is, therefore, reportedly affected by the following vulnerabilities :

- An error exists related to the implementation of the Elliptic Curve Digital Signature Algorithm (ECDSA) that could allow nonce disclosure via the 'FLUSH+RELOAD' cache side-channel attack. (CVE-2014-0076)
- A buffer overflow error exists related to invalid DTLS fragment handling that could lead to execution of arbitrary code. Note this issue only affects OpenSSL when used as a DTLS client or server. (CVE-2014-0195)
- An error exists related to DTLS handshake handling that could lead to denial of service attacks. Note this issue only affects OpenSSL when used as a DTLS client. (CVE-2014-0221)
- An unspecified error exists that could allow an attacker to cause usage of weak keying material leading to simplified man-in-the-middle attacks. (CVE-2014-0224)
- An unspecified error exists related to anonymous ECDH ciphersuites that could allow denial of service attacks. Note this issue only affects OpenSSL TLS clients. (CVE-2014-3470)

Acme mini_httpd Protocol String Handling Memory Disclosure:

The Acme mini_httpd web server running on the remote host is affected by a flaw in the add_headers() function within file mini_httpd.c that is triggered when handling HTTP requests that have a very long protocol string. An unauthenticated, remote attacker can exploit this, via a crafted request, to cause an out-of-bounds read error, resulting in the disclose of sensitive information in process memory.

Dropbear SSH Authorization-pending Connection Saturation DoS:

The remote host is running Dropbear, a small, open source SSH server.

The version of Dropbear installed on the remote host, by default, has a limit of 30 connections in the authorization-pending state; subsequent connections are closed immediately. This issue can be exploited trivially by an unauthenticated attacker to deny service to legitimate users.

SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE):

The remote host is affected by a man-in-the-middle (MitM) information disclosure vulnerability known as POODLE. The vulnerability is due to the way SSL 3.0 handles padding bytes when decrypting messages encrypted using block ciphers in cipher block chaining (CBC) mode.

MitM attackers can decrypt a selected byte of a cipher text in as few as 256 tries if they are able to force a victim application to repeatedly send the same data over newly created SSL 3.0 connections.

As long as a client and service both support SSLv3, a connection can be 'rolled back' to SSLv3, even if TLSv1 or newer is supported by the client and service.

The TLS Fallback SCSV mechanism prevents 'version rollback' attacks without impacting legacy clients; however, it can only protect connections when the client and service support the mechanism. Sites that cannot disable SSLv3 immediately should enable this mechanism.

OpenSSL 0.9.8 < 0.9.8zc Multiple Vulnerabilities (POODLE):

According to its banner, the remote web server uses a version of OpenSSL 0.9.8 prior to 0.9.8zc. The OpenSSL library is, therefore, affected by the following vulnerabilities :

- An error exists related to the way SSL 3.0 handles padding bytes when decrypting messages encrypted using block ciphers in cipher block chaining (CBC) mode. A man-in-the-middle attacker can decrypt a selected byte of a cipher text in as few as 256 tries if they are able to force a victim application to repeatedly send the same data over newly created SSL 3.0 connections. This is also known as the 'POODLE' issue. (CVE-2014-3566)
- An error exists related to session ticket handling that can allow denial of service attacks via memory leaks. (CVE-2014-3567)
- An error exists related to the build configuration process and the 'no-ssl3' build option that allows servers and clients to process insecure SSL 3.0 handshake messages. (CVE-2014-3568)

Remediations

To resolve the above vulnerabilities, here is a list of actions that need to be performed.

Severity	Vulnerability	IP/ DNS	Resolution
Critical	Microsoft RDP RCE (CVE-2019-0708)	BHCCWEB.BHS.local BHCS- Cashless.BHS.local	Impacted servers should be patched with the official patches distributed by Microsoft listed in the security notice
Critical	Apache < 2.4.49 Multiple Vulnerabilities	BHCCWEB.BHS.local	The web server should be updated to the latest version of Apache
Critical	ArubaOS-Switch Ripple20 Multiple Vulnerabilities (ARUBA-PSA-2020-006)	10.194.120.200	The affected switch should have its firmware updated or be replaced if it no longer in support
Critical	Microsoft Message Queuing RCE (CVE-2023-21554, QueueJumper)	BHCS- WebPublish.BHS.local	Impacted server should be patched with the official patches distributed by Microsoft listed in the security notice
High	OpenSSL < 0.9.8w ASN.1 asn1_d2i_read_bio Memory Corruption	BHCCWEB.BHS.local	The web server should be updated with the latest version of OpenSSL
High	PHP < 5.3.12 / 5.4.2 CGI Query String Code Execution	BHCCWEB.BHS.local	The web server should be updated with the latest version of PHP
High	PHP 5.3.x < 5.3.14 Multiple Vulnerabilities	BHCCWEB.BHS.local	The web server should be updated with the latest version of PHP
High	PHP 5.3.x < 5.3.28 Multiple OpenSSL Vulnerabilities	BHCCWEB.BHS.local	The web server should be updated with the latest version of PHP
High	Apache 2.2.x < 2.2.28 Multiple Vulnerabilities	BHCCWEB.BHS.local	The web server should be updated to the latest version of Apache
High	SSL Certificate Signed Using Weak Hashing Algorithm	10.194.120.1 10.194.120.171 BHCCWEB.BHS.local BHCS- Cashless.BHS.local BHCS- WebPublish.BHS.local	Servers should issue new SSL certificates with newer hashing algorithm
Medium	SMB Signing not required	Windows Machines	Signing should be enforced on all machines via group policy
Medium	OpenSSL 0.9.8 < 0.9.8za Multiple Vulnerabilities	BHCCWEB.BHS.local	The web server should be updated with the latest version of OpenSSL
Medium	Acme mini_httpd Protocol String Handling Memory Disclosure	10.194.120.171	The mini_httpd service on the device should be updated where this service is on an embedded device the devices firmware should be updated
Medium	Dropbear SSH Authorization-pending Connection Saturation DoS	10.194.120.171	The dropbear service on the device should be updated where this service is on an embedded device the devices firmware should be updated
Low	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)	10.194.120.42 10.194.120.171 10.194.121.49 BHCCWEB.BHS.local BHCS- WebPublish.BHS.local	SSLv3 should be disabled on impacted devices
Low	OpenSSL 0.9.8 < 0.9.8zc Multiple Vulnerabilities (POODLE)	BHCCWEB.BHS.local	The web server should be updated with the latest version of OpenSSL



For more information please contact us on the details below

☎ 0203 750 9796

✉ hello@eduthing.co.uk

🌐 eduthing.co.uk

📍 5 Walton Lodge, Walton, KT12 1BT

